

PASTA worksheet

Stages	Sneaker company
I. Define business and security objectives	• Protect users' personal and payment information • <i>Provide secure account sign up and login</i> • <i>Follow industry regulations for protecting payment and personal information</i>
II. Define the technical scope	I would prioritize SQL and SHA-256 because they are directly involved in storing and protecting sensitive user information. SQL could be vulnerable to attacks such as SQL injection, while weaknesses in password hashing could expose user credentials. Securing these technologies can help prevent unauthorized access to sensitive data.
III. Decompose application	• User → Product search process: Searching for sneakers for sale. The user submits a search query. • Product search process → Database: Request for listings. The process queries the database for matching sneakers. • Database → Product search process: Listings of current inventory. The database returns the inventory data • Product search process → User: Search results. The process displays the sneaker listings back to the user.
IV. Threat analysis	• External threat: SQL injection attack targeting the application database • External threat: Credential theft or phishing used to gain unauthorized access to user accounts
V. Vulnerability analysis	• Lack of prepared statements: This is a coding vulnerability in how the app talks to the database because the app doesn't use prepared statements, it allows the SQL injection attack path to steal user data. • Weak login credentials: This is an authentication vulnerability because user passwords are weak, it allows

	the session hijacking attack path to compromise user data.
VI. Attack modeling	• Exploit SQL injection → access database → steal user data. • Steal user credentials → log into account → access personal information.
VII. Risk analysis and impact	• Use parameterized SQL queries to prevent SQL injection. • Use strong password hashing to protect passwords. • Use encryption to protect sensitive data. • Use access controls and least privilege to restrict unauthorized access.
